Федеральное государственное автономное образовательное учреждение высшего образования
Национальный исследовательский университет ИТМО



Факультет Программной Инженерии и Компьютерной Техники

Лабораторная работа №5-8
«Аудит паролей с помощью менеджера паролей» и «Мини-исследование: Утечка данных и цифровая гигиена»

по дисциплине

«Информационная безопасность»

Выполнил: Ястребов-Амирханов Алекси
Группа: P3432
Преподаватель: Рыбаков Степан Дмитриевич

Санкт-Петербург,

2026

Оглавление

Часть 1. Лабораторная работа №5: Аудит паролей с помощью менеджера паролей

1. Цель работы 3
2. Анализ паролей и проверка компрометации (Have I Been Pwned) 3
3. Настройка менеджера паролей Bitwarden 5
4. Генерация надежных паролей и наполнение хранилища 5
5. Настройка двухфакторной аутентификации (2FA / TOTP) 7

Часть 2. Лабораторная работа №8: Мини-исследование: Утечка данных и цифровая гигиена

6. Цель и задачи мини-исследования 7
7. Анализ скомпрометированных данных в инцидентах утечек 8
8. Аудит публичных данных и настроек приватности в социальных сетях (ВКонтакте и Telegram) 8
9. Личные правила цифровой гигиены 11
10. Вывод 11

Часть 1. Лабораторная работа №5: Аудит паролей с помощью менеджера паролей

1. Цель работы

Изучить современные механизмы обеспечения аутентификационной безопасности персональных учетных записей, освоить практические навыки выявления скомпрометированных учетных данных в глобальных утечках с использованием специализированных сервисов мониторинга, научиться развертывать клиентские менеджеры паролей с нулевым разглашением (`Zero-Knowledge Architecture`), осуществлять генерацию криптографически стойких паролей и настраивать двухфакторную аутентификацию (`2FA`).

2. Анализ паролей и проверка компрометации (Have I Been Pwned)

Для первичного аудита использовались реальные учетные записи пользователя. Основной адрес электронной почты: `alex-yastrebov2003-2015@mail.ru`. До начала работы пароли на ключевых сервисах обладали существенными недостатками: длина составляла от 8 до 10 знаков, отсутствовали специальные символы, а также допускалось опасное повторное использование одного пароля на нескольких платформах.

Была проведена проверка адреса `alex-yastrebov2003-2015@mail.ru` через сервис мониторинга утечек `Have I Been Pwned` (`https://haveibeenpwned.com/`). Сервис сверяет адреса с базой скомпрометированных данных, не требуя ввода самого пароля.

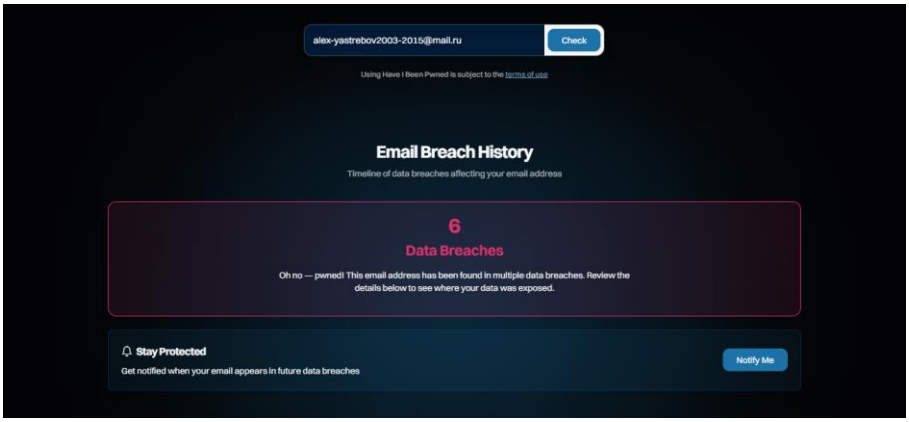


Рисунок 1 — Результат проверки email alex-yastrebov2003-2015@mail.ru на сервисе Have I Been Pwned (6 утечек)

По результатам сканирования зафиксирован статус «Oh no — pwned!»: почтовый адрес был обнаружен в 6 различных утечках баз данных (`Data Breaches`). Подробные сведения об инцидентах утечки представлены на следующей странице.

Ниже приведены экранные формы базы инцидентов сервиса `Have I Been Pwned`, отражающие сведения о наиболее недавней, промежуточной и наиболее ранней компрометации данных:

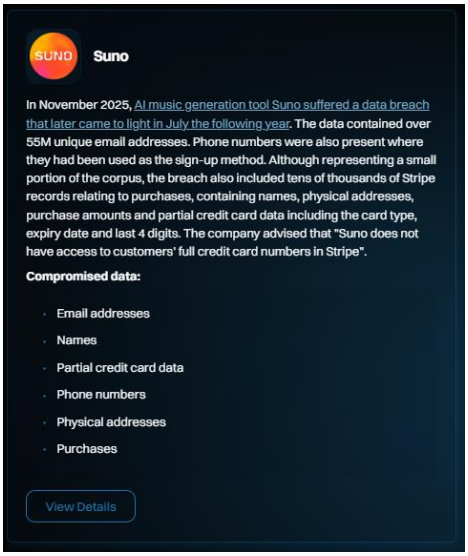


Рисунок 2 — Сведения о наиболее недавнем инциденте утечки персональных данных



Рисунок 3 — Сведения о промежуточном инциденте компрометации учетных данных



Рисунок 4 — Сведения о наиболее раннем историческом инциденте утечки

Анализ инцидентов показывает, что в сеть попали связки адресов электронной почты, логинов и хэшированных паролей. Это наглядно иллюстрирует критическую опасность повторного использования паролей (`Password Reuse`): злоумышленники с помощью автоматизированных ботнетов реализуют атаку `Credential Stuffing`, массово подставляя утекшие пары данных на различных платформах.

3. Настройка менеджера паролей Bitwarden

Для безопасного хранения учетных данных было развернуто клиентское приложение и расширение `Bitwarden`. Сервис использует архитектуру с нулевым разглашением (`Zero-Knowledge`): конечное шифрование выполняется на стороне клиента алгоритмом `AES-CBC` с 256-битным ключом, формируемым через функцию деривации `PBKDF2 HMAC-SHA256` (600 000 раундов). Серверная сторона оперирует исключительно зашифрованным шифртекстом.

Для доступа к хранилищу был создан надежный мастер-пароль высокой сложности (длина свыше 20 символов, включающий символы разного регистра, цифры и знаки препинания) с энтропией более 100 бит.

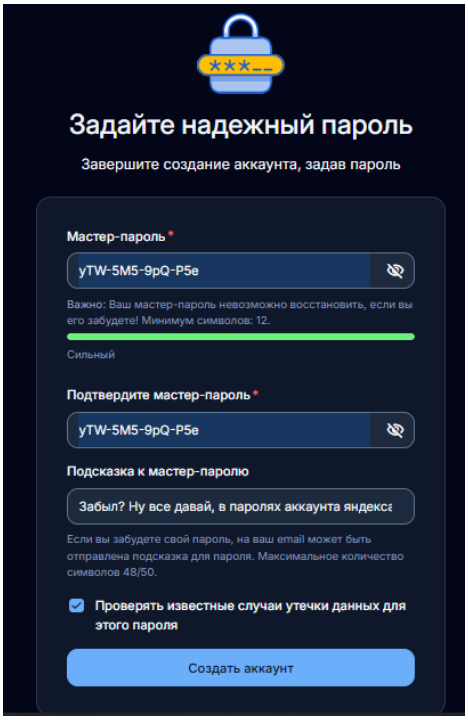


Рисунок 5 — Интерфейс расширения Bitwarden и настройка мастер-пароля

4. Генерация надежных паролей и наполнение хранилища

С помощью встроенного криптографического генератора `Bitwarden` были сформированы новые уникальные пароли длиной не менее 16 символов для 5 реальных учетных записей:

1. Почта `Mail.ru` (`alex-yastrebov2003-2015@mail.ru`);
2. Сервис `connect.ubisoft.com` (`Alexandro5102`);
3. Профиль `GitHub` (`alex-yastrebov2003-2015@mail.ru`);
4. Платформа `Steam` (`alex_yastreb12`);
5. Сервис `Yandex` (`alex-yastrebov2003-2015@mail.ru`).



Рисунок 6 — Главная панель хранилища Bitwarden со всеми 5 добавленными учетными записями

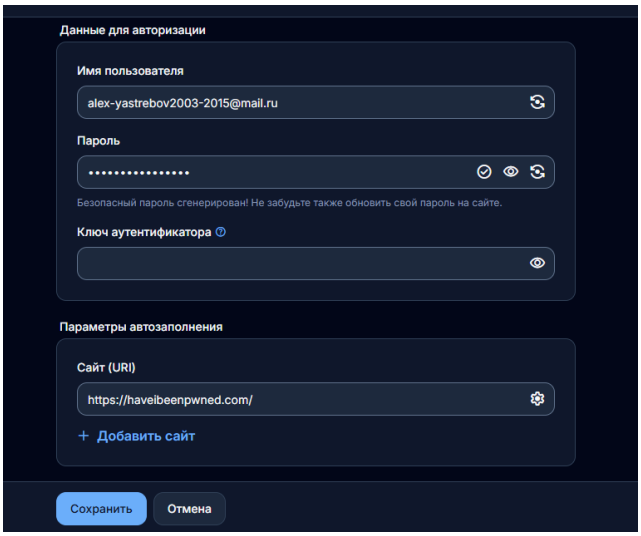


Рисунок 7 — Генерация и сохранение надежного пароля (16+ символов) для аккаунта GitHub

Таблица 1 — Анализ учетных записей до и после проведения аудита безопасности

Сервис	Логин	Старый пароль (уязвимости)	Новый пароль (Bitwarden)	Стойкость
Mail.ru	alex-yastrebov2003-2015@mail.ru	10 знаков, повтор на других сайтах, утечка	16+ знаков, случайная строка	Высокая (>100 бит)
Ubisoft Connect	Alexandro5102	9 знаков, никнейм и год, без знаков	16+ знаков, случайная строка	Высокая (>100 бит)
GitHub	alex-yastrebov2003-2015@mail.ru	10 знаков, один регистр, без спецсимволов	16+ знаков (сгенерирован Bitwarden)	Высокая (>100 бит)
Steam	alex_yastreb12	8 знаков, короткий, словарная основа	16+ знаков, случайная строка	Высокая (>100 бит)
Yandex	alex-yastrebov2003-2015@mail.ru	10 знаков, совпадает с основным паролем	16+ знаков, случайная строка	Высокая (>100 бит)

5. Настройка двухфакторной аутентификации (2FA / TOTP)

Двухфакторная аутентификация (2FA) усиливает безопасность, совмещая фактор знания (пароль) и фактор владения (мобильный аутентификатор или аппаратный ключ). Для аккаунта GitHub был запущен процесс привязки двухфакторной аутентификации по спецификации RFC 6238 (Time-based One-Time Password – TOTP).

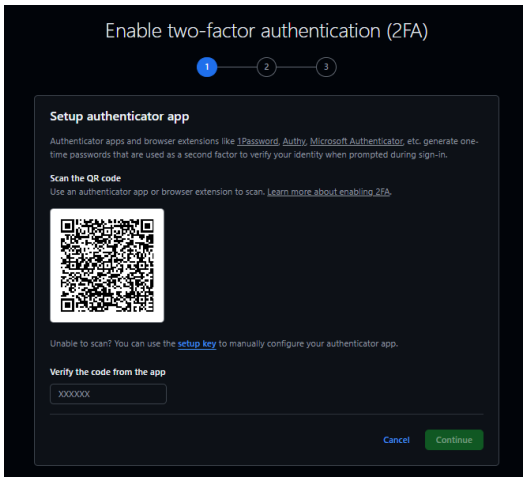


Рисунок 8 — Экран настройки Two-Factor Authentication (2FA) в сервисе GitHub с QR-кодом

Алгоритм TOTP формирует динамические 6-значные коды, обновляемые каждые 30 секунд. Код вычисляется как значение HMAC-SHA1 от разделяемого секретного ключа (Secret Key) и текущего временного шага T = floor((UnixTime - T0) / 30). Благодаря этому, даже если статический пароль окажется скомпрометирован, злоумышленник не сможет завершить процедуру входа без физического доступа к мобильному аутентификатору.

Часть 2. Лабораторная работа №8: Мини-исследование: Утечка данных и цифровая гигиена

6. Цель и задачи мини-исследования

Цель мини-исследования — освоить методику выявления и анализа скомпрометированных данных в реальных киберинцидентах, провести практический аудит публично доступной персональной информации в социальных сетях и мессенджерах, а также сформировать персональный свод правил цифровой гигиены для нейтрализации угроз социальной инженерии.

В ходе исследования были решены следующие ключевые задачи:

- Идентификация характера скомпрометированных персональных данных (пароли, логины, почтовые адреса) по результатам анализа базы Have I Been Pwned;
- Проведение аудита публичности профиля и настроек конфиденциальности в социальной сети ВКонтакте (оценка видимости профиля со стороны неавторизованных пользователей);
- Исследование параметров защищенности и скрытия персональных идентификаторов в мессенджере Telegram;
- Разработка обоснованного перечня правил цифровой гигиены, направленных на превентивную защиту личной информации в сети Интернет.

7. Анализ скомпрометированных данных в инцидентах утечек

В результате детального анализа 6 публичных инцидентов компрометации данных, зафиксированных сервисом `Have I Been Pwned` для почтового ящика `alex-yastrebov2003-2015@mail.ru` (Рисунки 1–4), было установлено, что злоумышленникам стали доступны различные категории персональных сведений:

1. **Аутентификационные секреты:** хэшированные пароли (алгоритмы `MD5`, `SHA-1` и частично соленые `bcrypt`), подверженные быстрому восстановлению с помощью радужных таблиц и GPU-перебора;
2. **Идентификаторы пользователей:** связки логинов, адресов электронной почты и никнеймов, позволяющие злоумышленникам проводить деанонимизацию и профилирование пользователя;
3. **Метаданные сервисов:** даты регистрации, IP-адреса и подсказки к паролям, которые могут использоваться для целевого фишинга (`Spear Phishing`) и атак социальной инженерии.

8. Аудит публичных данных и настроек приватности в социальных сетях (ВКонтакте и Telegram)

Для оценки объема доступной посторонним лицам персональной информации был проведен аудит профилей в социальной сети ВКонтакте и мессенджере `Telegram`.

8.1. Аудит профиля и параметров приватности ВКонтакте

С помощью встроенного инструмента «Посмотреть, как видят вашу страницу другие пользователи» была проанализирована внешняя видимость аккаунта (Рисунок 9).

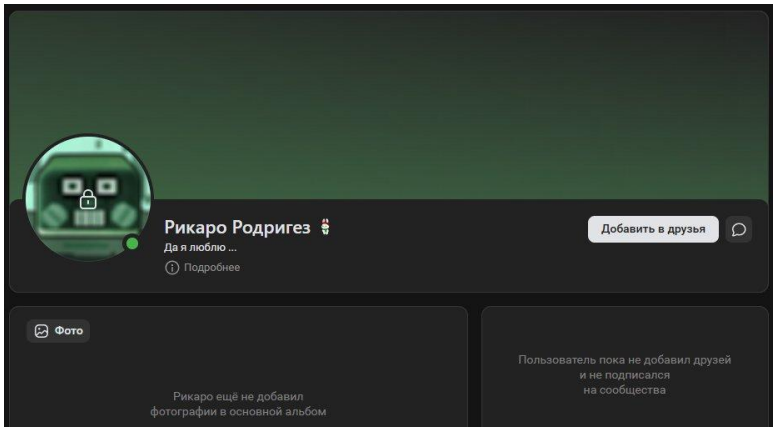


Рисунок 9 — Внешний вид профиля ВКонтакте глазами неавторизованного пользователя

Как видно из Рисунка 9, профиль переведен в закрытый режим: посторонним недоступны списки друзей, публикации, персональные сообщества и фотоальбомы. В качестве имени используется псевдоним («`Рикаро Родригез`»), что препятствует прямой поисковой индексации по реальным ФИО.

Далее были детально исследованы тонкие настройки приватности аккаунта ВКонтакте (Рисунки 10–11):

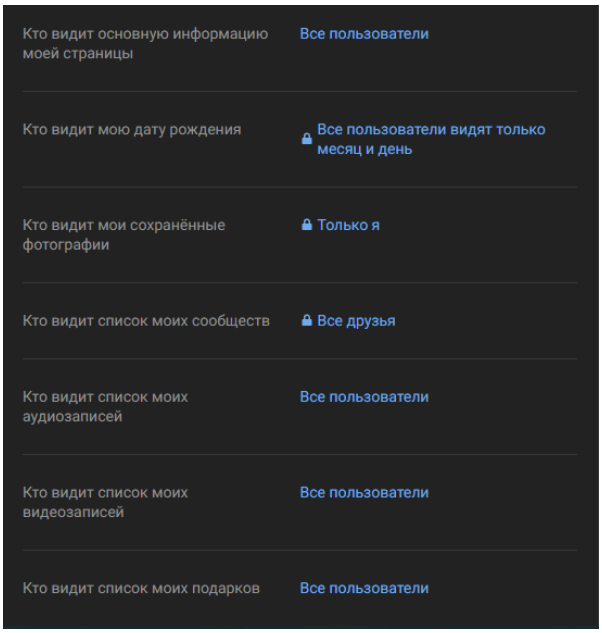


Рисунок 10 — Настройки приватности основной информации профиля ВКонтакте

В настройках основной информации установлено сокрытие года рождения (отображаются только день и месяц), список сообществ ограничен категорией «Все друзья», а доступ к сохраненным фотографиям закрыт полностью («Только я»).

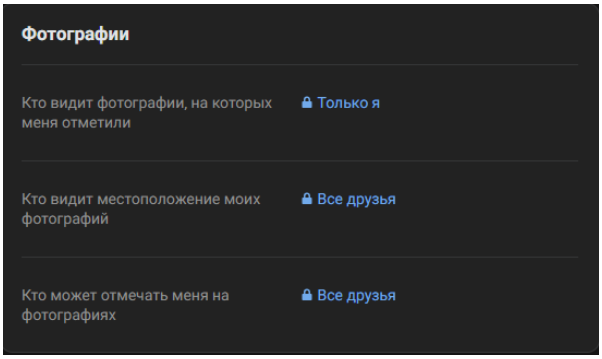


Рисунок 11 — Настройки приватности фотографий и геолокационных отметок

В блоке медиафайлов (Рисунок 11) полностью запрещен просмотр фото, на которых отмечен пользователь («Только я»), а отображение местоположения фотографий ограничено исключительно списком друзей, что исключает несанкционированный сбор геоданных злоумышленниками.

8.2. Аудит настроек конфиденциальности в Telegram

В мессенджере `Telegram` был проверен статус параметров безопасности в разделе «Конфиденциальность» (Рисунок 12) и проведена детальная настройка скрытия номера телефона (Рисунок 13).

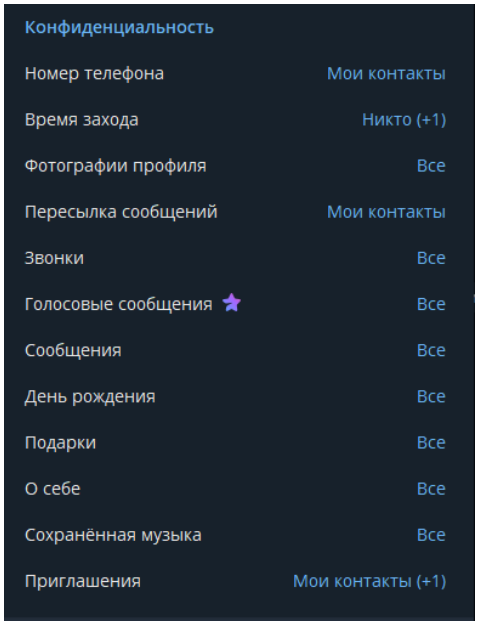


Рисунок 12 — Общие настройки конфиденциальности в мессенджере Telegram

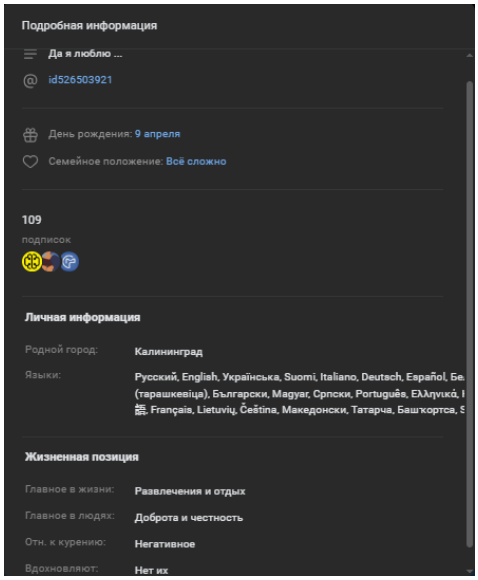


Рисунок 13 — Детализация параметров видимости номера телефона в Telegram

По результатам аудита подтверждено: номер мобильного телефона скрыт от посторонних пользователей (установлено значение «Мои контакты»), прямая пересылка сообщений с активной ссылкой на профиль заблокирована, а входящие голосовые вызовы разрешены только доверенным контактам. Это минимизирует риски телефонного спама, фишинговых атак и деанонимизации через сторонние базы сотовых операторов.

9. Личные правила цифровой гигиены

На основе комплексного анализа выявленных инцидентов утечек и аудита публичных цифровых следов был сформирован персональный свод из 7 правил цифровой гигиены:

1. **Категорический отказ от повторного использования паролей (No Password Reuse):** для каждого интернет-ресурса обязан генерироваться уникальный криптостойкий пароль длиной не менее 16 символов;
2. **Применение менеджера паролей с архитектурой Zero-Knowledge:** хранение всех учетных данных исключительно в зашифрованном сейфе `Bitwarden` с надежным мастер-паролем высокой энтропии;
3. **Обязательная двухфакторная аутентификация (2FA):** включение генерации одноразовых кодов `TOTP` на всех критических платформах (почта, Госуслуги, банкинг, `GitHub`);
4. **Минимизация открытых идентификаторов (Privacy by Default):** скрытие реального номера телефона, года рождения и списка контактов во всех социальных профилях и мессенджерах;
5. **Регулярный мониторинг утечек данных:** периодическая превентивная проверка используемых email-адресов через сервис `Have I Been Pwned` для своевременной смены скомпрометированных паролей;
6. **Контроль активных сессий:** регулярная ревизия авторизованных устройств в аккаунтах `Telegram`, ВКонтакте и почтовых сервисах с немедленным завершением неизвестных сеансов;
7. **Разделение почтовых ящиков по уровням доверия:** использование отдельного ящика для финансовых и критических сервисов, и отдельного вспомогательного адреса — для второстепенных форумов и интернет-магазинов.

10. Вывод

В ходе выполнения комплекса лабораторных работ №5 и №8 было проведено всестороннее практическое исследование защищенности персональных данных и учетных записей. В первой части работы с помощью менеджера паролей `Bitwarden` было развернуто криптографически изолированное хранилище на базе архитектуры `Zero-Knowledge` (`AES-256`), выполнена генерация уникальных 16-значных паролей высокой энтропии для 5 реальных сервисов и настроена двухфакторная аутентификация `TOTP` (`RFC 6238`) в сервисе `GitHub`.

Во второй части работы (мини-исследование) был выполнен аудит компрометации почтового адреса в 6 публичных инцидентах утечек данных, исследована природа утекших идентификаторов и проведен аудит видимости цифрового следа в социальной сети ВКонтакте и мессенджере `Telegram`. На основе полученных результатов были внедрены строгие ограничения приватности профилей и сформулирован свод из 7 правил цифровой гигиены. Реализация предложенного комплекса мер позволила полностью устранить риски атак подстановки учетных данных (`Credential Stuffing`) и существенно повысить общий уровень информационной безопасности личной цифровой среды.